420-1C1-DW Preventative Monitoring · Class 16

Topic 5 — Detecting and Diagnosing Anomalies (end)

- 5.3 Analyzing anomalies step by step
- 5.4 Diagnosing incidents and documenting the findings
- 5.5 Communicating results to the people concerned
- Quiz 3 (5%): Topics 3 and 4



Thursday, October 15, 2026 · Online · Cybersecurity: Prevention and Intervention, LEA.D8 **AEC** (Attestation d'études collégiales, a college attestation program)

Educational material — Cyber.SoHo / Asen Grozdanov. © 2026 Cyber.SoHo. All rights reserved. Use is governed by the Cyber.SoHo Legal Notice, Terms of Use and Acceptable Use Policy v2.0 (link on slide 2). All data are fictional.

Before we start: rules of use

- Educational material: Cyber.SoHo / Asen Grozdanov, © 2026 Cyber.SoHo. All rights reserved.
- Isolated, authorized lab only, against the designated targets. Anything else without the owner's written authorization may be a criminal offence (Criminal Code, sections 342.1, 342.2, 430(1.1) and 184).
- Monitoring data are treated as personal information: keep the minimum, never share, delete when marked (section 7.2).
- Evidence handling: originals read-only, work on copies, record hashes and times (section 7.8).
- All companies, people, addresses and records of this class are fictional (Atelier Nordik inc.).

Full terms

Cyber.SoHo Legal Notice, Terms of Use and Acceptable Use Policy (v2.0)

Sections 6.1 (authorization), 7.2 (monitoring data), 7.8 (evidence), 17 (confidentiality), 18 (academic integrity).

Plan of the class

5.3 Analyze

Five steps: collect, timeline, benign explanations first, corroborate, conclude

5.4 Diagnose and document

Category, root cause, scope, exposure, impact, priority, confidence, evidence integrity

5.5 Communicate

Who needs to know, when, which channel, which label; plain language; Québec and Canadian law

Quiz Quiz 3 (5%)

Topics 3 and 4 as taught (3.1 to 3.5, 4.1, 4.2); details at the end of the module

Today’s case: alert A-09

One alert of the Class 15 queue is taken from the analysis to the note for the owner. The same method serves Lab 3, Parts C and D. Quiz 3 follows the hour.

Learning outcomes

1. Analyze an alert in five steps and produce a timeline and a hypothesis table (5.3)
2. Diagnose it: category, root cause, scope, exposure window, impact, priority, technique, confidence (5.4)
3. Protect evidence with **SHA-256** (Secure Hash Algorithm, 256-bit) hashes, a register and a chain of custody; write the diagnosis record (5.4)
4. Communicate: who, when, channel, **TLP** (Traffic Light Protocol) label, legal duties; owner note and technical annex (5.5)

Competency EZ01, element 4: methodical analysis, rigorous analysis of anomalies, accurate diagnosis of incidents

Where we are in the course



- Triage decides the order of work; only the analysis shows what happened.
- **NIST** (National Institute of Standards and Technology) Cybersecurity Framework 2.0, Respond function: Incident Analysis (**RS.AN**) for lessons 5.3 and 5.4, Incident Response Reporting and Communication (**RS.CO**) for lesson 5.5.

Official sources: **NIST** (National Institute of Standards and Technology) Cybersecurity Framework 2.0 · **NIST** (National Institute of Standards and Technology) **SP** (Special Publication) 800-61 Revision 3 (April 2025)

The case of the day: alert A-09

P3

Alert	A-09: definition update failed on 3 workstations
Raised	Saturday, October 10, 09:30, daily device-health check
Assets	WS-10-22, WS-10-37, WS-10-51 (rendering workstations)
Triage	impact 2 × confidence 3 = 6, band **P3** (priority 3)
Case	CASE-2026-016, opened Tuesday, October 13, 08:55

- Why A-09? Lab 3, Part C diagnoses two **P1** (priority 1) items of your queue; the method is the same, so the class uses A-09.
- Setting: Atelier Nordik inc., 14 people, Montréal; 12 workstations; policies Render-WS (3 rendering workstations) and Studio-WS (9 others).
- Microsoft Defender Antivirus, managed from a cloud console by the **IT** (information technology) contractor (account contractor-it, office address 203.0.113.150).

The evidence pack: E-01 to E-11

Id	File	Source system	Group	Time	Phase
E-01	a09_alert.csv	Alert queue on MON-250 (raised by the antivirus console)	console	09:02	analysis
E-02	av-console_device-status_2026-10-13.csv	Antivirus console (cloud)	console	09:05	analysis
E-03	av-console_update-history_2026-10-08_13.csv	Antivirus console (cloud)	console	09:06	analysis
E-04	av-console_audit_2026-10-01_13.csv	Antivirus console (cloud)	console	09:08	analysis
E-05	ws-render_defender-events_2026-10-08_13.csv	WS-10-22, WS-10-37, WS-10-51	workstations	09:12	analysis
E-06	srv-ad01_shares_2026-10-13.txt	SRV-AD01 (file server)	srv-ad01	09:20	analysis
E-07	change-log_contractor_2026-10.csv	Change log of the **IT** (information technology) contractor (shared spreadsheet)	change-log	09:22	analysis
E-08	maintenance_calendar.csv	Maintenance calendar on MON-250 (used by triage)	calendar	09:23	analysis
E-09	ws-render_defender-events_after-fix_2026-10-13.csv	WS-10-22, WS-10-37, WS-10-51	workstations	12:24	verification
E-10	av-console_audit_after-fix_2026-10-13.csv	Antivirus console (cloud)	console	12:25	verification
E-11	av-console_device-status_after-fix_2026-10-13.csv	Antivirus console (cloud)	console	12:26	verification

Five independence groups: console, workstations, srv-ad01, change-log, calendar. Fictional data; 203.0.113.150 is a documentation address (**RFC** (Request for Comments) 5737).

5.3

Analyzing anomalies step by step

What exactly happened?

In what order?

How sure are we?

Key terms of analysis

Analysis

Systematic examination of the records of an alert: facts, order, cause

Evidence

Any record that can support or contradict a statement about what happened

Hypothesis

A possible explanation that makes predictions you can check

Corroboration

Confirmation of a fact by a second, independent source

Finding

A statement established by the analysis, with its evidence

Confidence

How strongly the evidence supports a finding: low, medium, high

Three errors that the method prevents

! Confirmation bias

Looking only for evidence that fits the explanation you prefer.

Prevention: Write every hypothesis first; test the benign ones first.

! Mixed time zones

Console in **UTC** (Coordinated Universal Time), workstations in local time with an offset, alert queue without an offset.

Prevention: Convert every time to one zone before sorting.

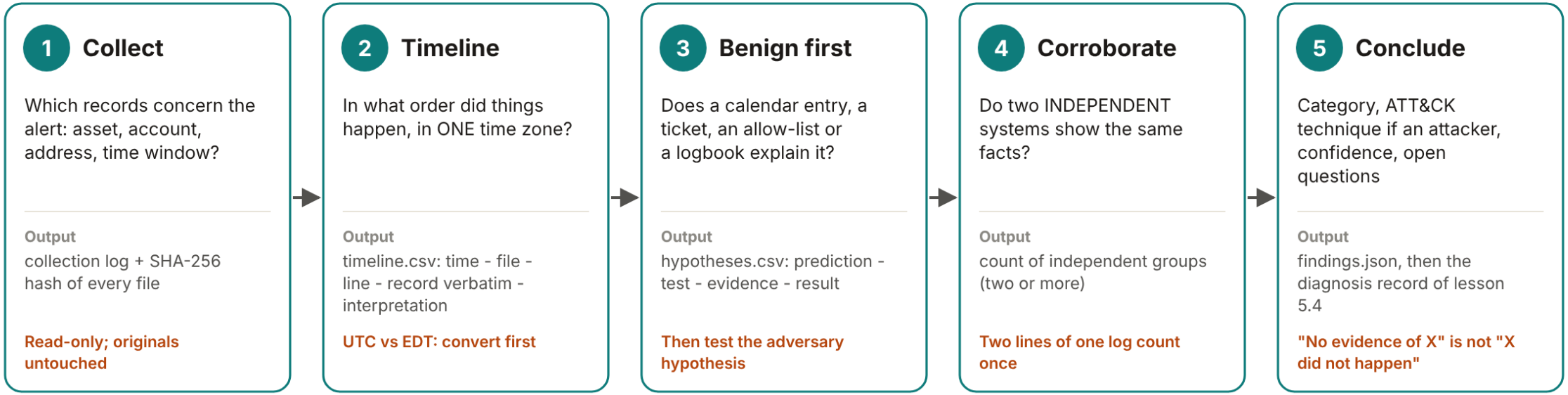
! Single source

One record shows only what one system recorded; a console or an account can be wrong.

Prevention: Confirm each important fact with two independent sources.

The five steps of the analysis

Figure 5.3-1 The five analysis steps of lesson 5.3 (the same steps as Lab 3, Part C)



Class 16 applies the five steps to alert A-09 (P3). Lab 3 Part C applies them to two of the four P1 items; Part D reports them.

Each step produces a file: collection log, timeline, hypothesis table, count of independent groups, findings.

Step 1: Collect

- Scope from the alert: assets, accounts, addresses, and a time window that starts before the first symptom (A-09: from Thursday, October 8).
- Read-only methods only: console export, Get-WinEvent, Get-SmbShare, Test-Path. No restart, no deletion, no "quick fix" before collection.
- Collection log: identifier, file, source system, independence group, collector, time, method, phase.
- **SHA-256** (Secure Hash Algorithm, 256-bit) hash of every file at collection (lesson 5.4).
- A-09: 8 files collected from 09:02 to 09:23 on Tuesday, from 5 groups: console, workstations, srv-ad01, change-log, calendar.



Output: collection log and hashes

Order of volatility: collect what disappears first

Order	Category (RFC (Request for Comments) 3227, section 2.1)	Example at Atelier Nordik
1	Registers, cache	Processor cache of WS-10-22 (specialist tools only)
2	Routing table, **ARP** (Address Resolution Protocol) cache, process table, kernel statistics, memory	Get-Process, Get-NetTCPConnection, arp -a; a memory image
3	Temporary file systems	%TEMP% on Windows, /tmp on srv-web01
4	Disk	Event log files, configuration files, user files
5	Remote logging and monitoring data relevant to the system	MON-250 central logs; antivirus console exports
6	Physical configuration, network topology	Lab 1 network diagram, switch and firewall configuration
7	Archival media	Backups of SRV-AD01

Collect the most volatile first. For A-09, nothing volatile was needed: the facts were in logs, exports and a ticket.

Official sources: **IETF** (Internet Engineering Task Force) **RFC** (Request for Comments) 3227, Guidelines for Evidence Collection and Archiving, section 2.1

Step 2: Timeline in one time zone

- One list of all relevant records, sorted by time, in one time zone.
- Montréal in October: **EDT** (Eastern Daylight Time) = **UTC** (Coordinated Universal Time) minus 4 hours (**EST** (Eastern Standard Time), **UTC** (Coordinated Universal Time) minus 5 hours, from November 1, 2026).
- Each row: time, identifier, file, line, record verbatim, one interpretation.
- Identical repeats: keep first, last and count (84 failures become 6 rows).
- Clocks must agree: computers synchronize with **NTP** (Network Time Protocol); seconds matter.

Console record (UTC, Coordinated Universal Time)

`2026-10-08T21:42:10Z`

↓ **minus 4 hours**

Same moment, local time

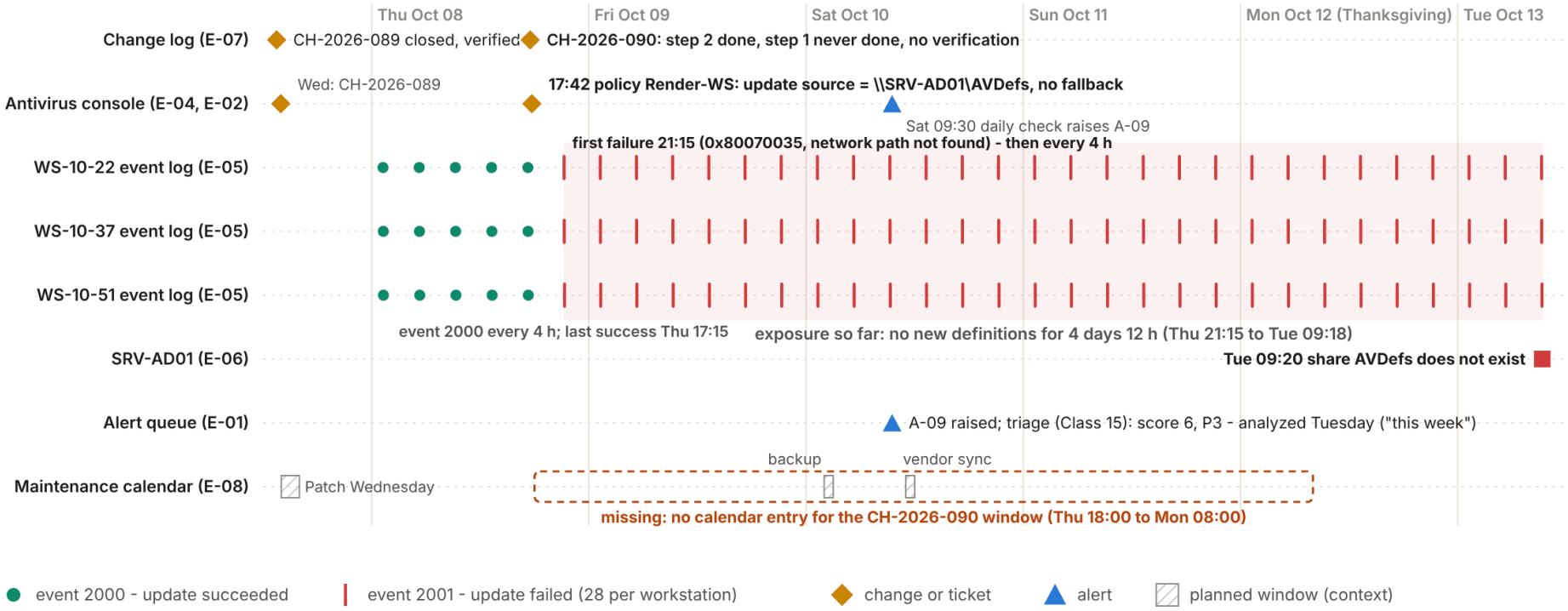
Thursday, October 8, 17:42:10 EDT (Eastern Daylight Time)

Z means **UTC** (Coordinated Universal Time); subtract 4 hours in October

The A-09 timeline

Figure 5.3-2 Alert A-09: one timeline in Eastern Daylight Time (EDT), seven evidence files, five groups

Each mark is one record of the evidence pack; the console wrote its times in UTC and was converted (21:42Z = 17:42 EDT).

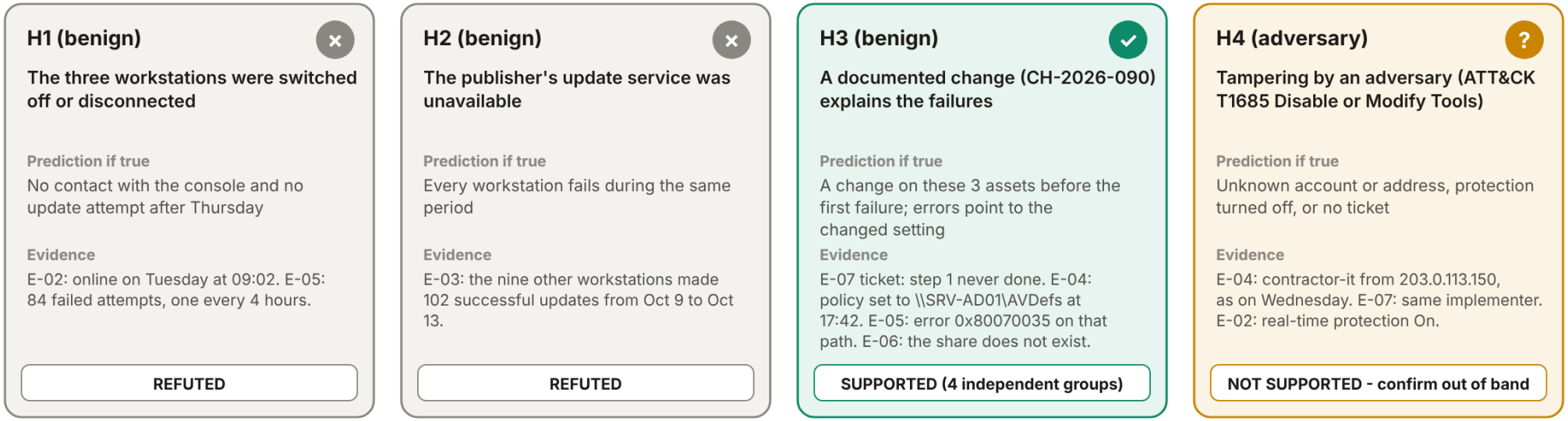


The change comes 3 h 33 min before the first failure; the 4-hour gap between the last success and the first failure is the update interval.

Step 3: Benign explanations first, then the adversary

- Write each hypothesis with its prediction and the test that could refute it.
- Benign first: more frequent, cheaper to check. Then always the adversary hypothesis.
- Results: supported, refuted, not supported, undetermined. A refuted hypothesis is a result.

Figure 5.3-3 Step 3 and step 4: benign explanations first, then the adversary hypothesis



Order of testing: H1 → H2 → H3 (benign) before H4 (adversary). A refuted hypothesis is a result, and it is written down.

Step 4: Corroborate with independent sources

- Independent: an error or a falsification in one source cannot change the other.
- Two records of the same system count once.
- A person reached out of band (number from the contract) is a separate source.
- Minimum two groups for a finding; three or more for high confidence.

✓ **Workstations** E-05

✓ **Console** E-04

✓ **SRV-AD01** E-06

✓ **Change log** E-07

✓ **Phone, 09:50** out of band

H3 supported by 4 independent groups (+ phone)

Step 5: Conclude

"No evidence of X" is not "X did not happen".

- Preliminary conclusion: category, technique if there is an attacker, confidence, open questions.
- A missing record proves nothing if the source could not have recorded the event: write what was checked.

A-09, preliminary conclusion

Monitoring failure	No technique	High	4 d 12 h
category	T1685 to confirm by phone	confidence	exposure so far

Open questions: confirm the change by phone; full scan after the update; why step 1 was skipped and the calendar not updated.

Videos for lesson 5.3

Network Troubleshooting Methodology - CompTIA Network+ N10-009 - 5.1

Professor Messer · 8:04 · YouTube

The same reasoning as lesson 5.3, applied to network problems: identify what changed, propose theories, test them, verify, document.

Watch for: the steps "identify the problem", "establish a theory", "test the theory" and "document findings": they correspond to collection, hypotheses, tests and the written conclusion.

Watch on YouTube · **Video page and notes**
https://www.youtube.com/watch?v=dovuPm3dGhc

Log Data - CompTIA Security+ SY0-701 - 4.9

Professor Messer · 13:41 · YouTube

Review of Class 14 with a new purpose: the data sources that support an investigation, the files you collect in step 1 and compare in step 4.

Watch for: For each source he shows, ask: what can it prove, and is it independent of the others?

Watch on YouTube · **Video page and notes**
https://www.youtube.com/watch?v=EDru1LTYDJw

Checked October 12, 2026: confirmed by YouTube oEmbed; lengths from the official professormesser.com course index.

Example 5.3: analyze A-09 with a script

TASK

Analyze A-09 from the evidence pack with the five steps; write a09_timeline.csv, a09_hypotheses.csv, a09_findings.json.

RELATION TO THE LECTURE

One function per step: step1_collect, step2_timeline, step3_hypotheses, step4_corroborate, step5_conclude.

FUTURE LAB

Lab 3, Part C: the same three outputs for two **P1** (priority 1) items of your queue (template timeline_template.csv).

```
$ python3 scripts/analyze_anomaly.py
outputs: a09_timeline.csv · a09_hypotheses.csv · a09_findings.json
Fictional data only; never on a real system (Legal Notice, section 6.1).
```

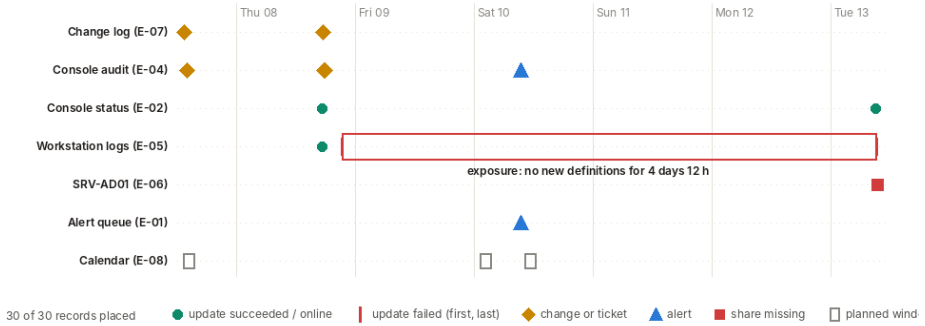
Example 5.3: what the script finds

```
$ python3 scripts/analyze_anomaly.py

STEP 1 - COLLECT the evidence (files listed in collection_log.csv, phase 'analy…
  -> 8 files from 5 independent groups: calendar, change-log, console, srv-ad01…
STEP 2 - TIMELINE in one time zone (EDT); every record is quoted verbatim
  time zone: the console writes 2026-10-08T21:42:10Z (UTC) = Thu 2026-10-08 17:…
  13 Thu 2026-10-08 17:42:10  E-04  Policy Render-WS: update source set to the …
  17 Thu 2026-10-08 21:15:04  E-05  WS-10-22: FIRST failure, source File share …
  21 Sat 2026-10-10 09:30:00  E-01  Alert A-09 raised; triage of Class 15: scor…
  30 Tue 2026-10-13 09:20:00  E-06  The share \\SRV-AD01\AVDefs does not exist …
STEP 3 - BENIGN EXPLANATIONS FIRST
  H1 [benign  ] REFUTED  The three workstations were switched off or disconnect…
  H2 [benign  ] REFUTED  The publisher's update service was unavailable
  H3 [benign  ] SUPPORTED  A documented change (CH-2026-090) explains the failu…
  H4 [adversary] NOT SUPPORTED (confirm by phone) Someone tampered with the ant…
STEP 4 - CORROBORATE with independent sources (two records of the same system c…
  H3 is supported by 4 independent groups: change-log, console, srv-ad01, works…
STEP 5 - CONCLUDE (preliminary; the diagnosis record of lesson 5.4 makes it fin…
  category: monitoring failure | ATT&CK: none (T1685 tested: NOT SUPPORTED (con…
  exposure so far: Thu 2026-10-08 21:15:04 -> Tue 2026-10-13 09:18:23 (4 days 1…
  priority: triage P3 -> P2 (impact 2 x confidence 5 = 10)
```

Figure 5.3-4 Building the A-09 timeline: every record placed in time order (EDT)

Result: 17:42 policy change → 21:15 first failure → 28 failures each → share missing. One sequence, one time zone.



Animation: the 30 rows of the timeline are placed in time order, one record at a time (Figure 5.3-4). In slide show mode the animation plays.

Check-in: lesson 5.3

Question 1 · Multiple choice (one answer)

The console exported the record "2026-10-08T21:42:10Z, Policy modified, Render-WS". A workstation log shows the first failed update at "2026-10-08T21:15:04-04:00". Which statement is correct?

a) The policy change happened at 17:42 **EDT** (Eastern Daylight Time), about 3 hours 33 minutes before the first failure.

b) The two times cannot be compared because one of them has no time zone.

c) The console clock is 4 hours late, so its records must be discarded.

d) The policy change happened 27 minutes after the first failure, so it cannot be the cause.

Question 2 · Multiple select (select 3)

Which actions belong to step 1 (collect) of the method?

a) Compute the **SHA-256** (Secure Hash Algorithm, 256-bit) hash of each file at collection time.

b) Restart the three workstations to see whether the update works after a reboot.

c) Export the audit log of the antivirus console to a **CSV** (comma-separated values) file.

d) Write in the collection log who collected each file, when, how and from which system.

e) Delete the policy Render-WS to stop the failures.

f) Write the final category in the diagnosis record.

Answers and explanations: in the module (Show the answer) and in the notes of this slide.

5.4

Diagnosing incidents and documenting the findings

What kind of problem is it?

Why did it happen, and how far did it reach?

Can anyone check our files and our reasoning?

Key terms of diagnosis

Event

Any observable occurrence: a logon, an update, a policy change

Security incident

Actual or imminent harm, without lawful authority, to integrity, confidentiality or availability; or a violation of law or security policy (**NIST**, National Institute of Standards and Technology)

Monitoring failure

A monitoring or protection tool stops collecting data or stops protecting, without an attacker

Benign true positive

Rule correct, activity authorized and expected; a false positive is a wrong rule

Diagnosis

The documented decision: category, cause, scope, impact, priority, technique, confidence

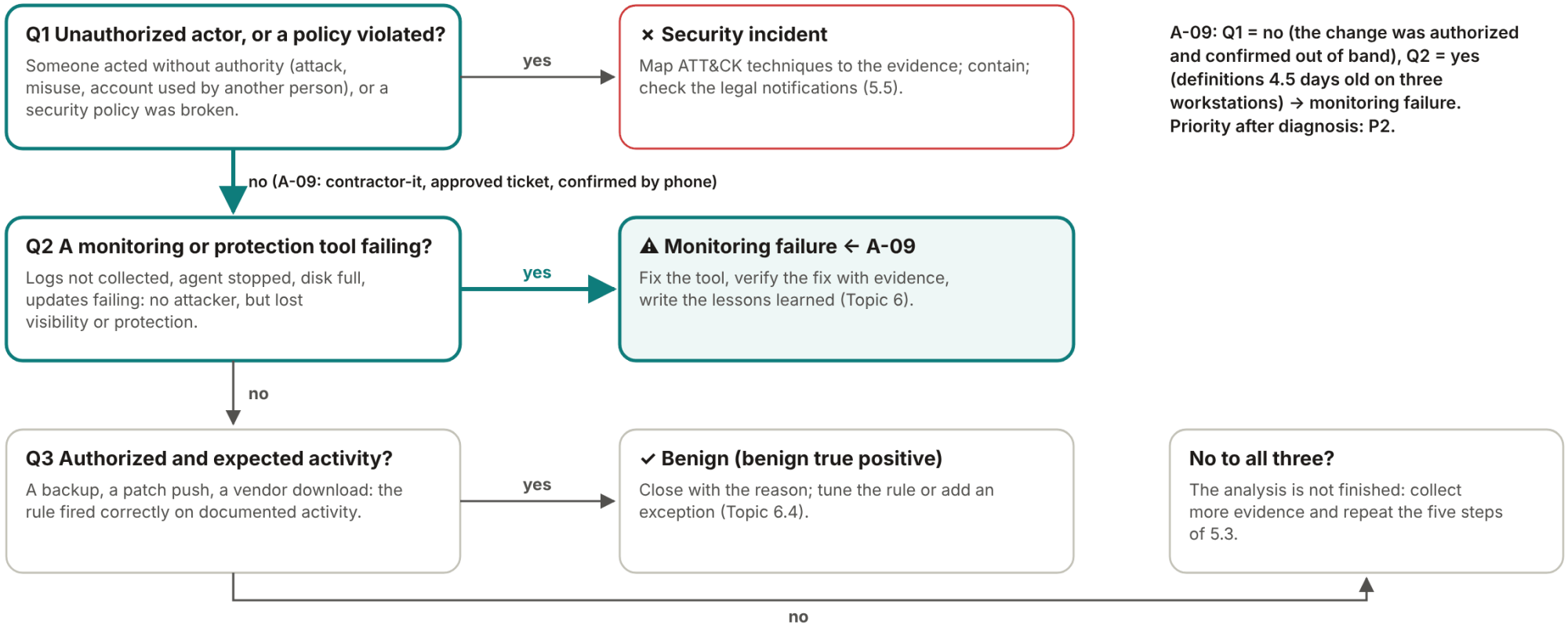
Diagnosis record

The document that holds the diagnosis and the evidence references

Official sources: **NIST** (National Institute of Standards and Technology) glossary: incident

Three questions decide the category

Figure 5.4-1 Three questions decide the category (the first "yes" wins) - path of A-09 in teal



First "yes" decides. "No" to all three: the analysis is not finished.

Root cause: ask "why?" until you reach a process

1. Why did the updates fail? The source \\SRV-AD01\AVDefs does not exist (E-05, E-06).
2. Why does the policy point there? Step 2 of CH-2026-090 was applied on Thursday at 17:42 (E-04, E-07).
3. Why does the share not exist? Step 1, planned for Friday at 09:00, was never done (E-07).
4. Why did nobody notice? No verification step, no calendar entry; the daily check waits for 24 hours without a successful update.

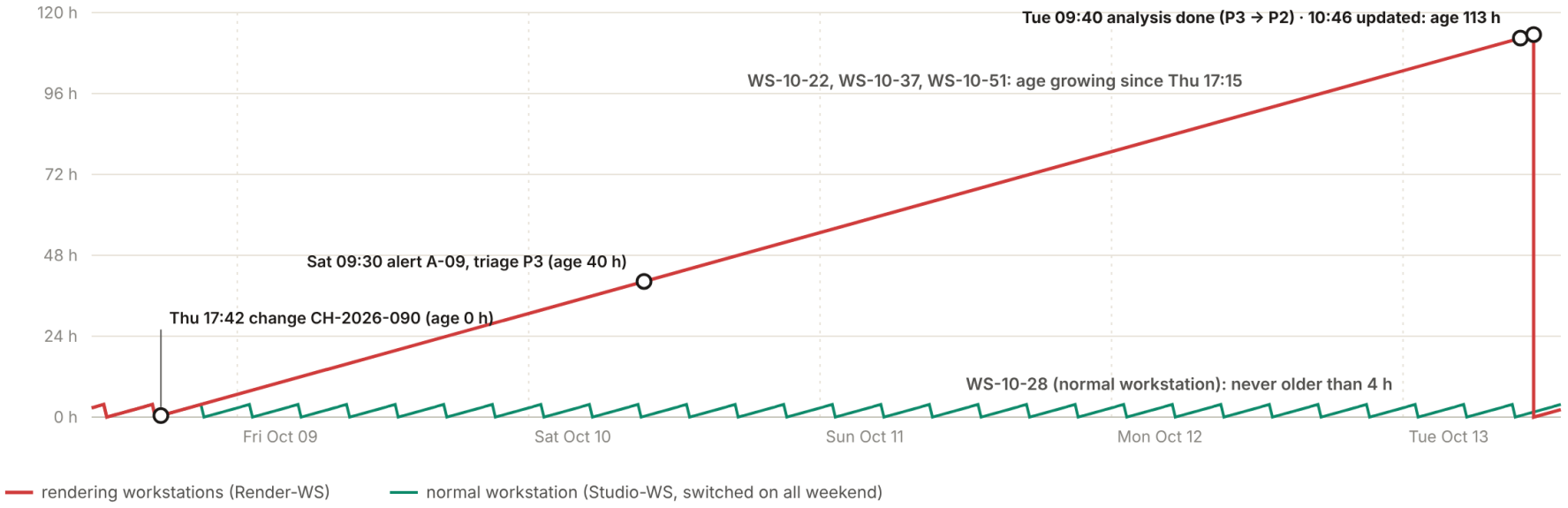
Root cause: the change process allowed a change without a verification step and without a calendar entry.

Immediate cause: the update source points to a missing share. Write a root cause as a fact about a process, never as a judgment about a person.

Scope and exposure window, measured from evidence

- Scope: 3 workstations; no account; no data accessed, changed or lost.
- Exposure window: first failed update (Thursday 21:15) to last workstation updated (Tuesday 10:46) = 4 days 13 h 31 min.
- Detection delay: Thursday 21:15 to Saturday 09:30 = 36 h 15 min.

Figure 5.4-2 Age of the antivirus definitions (hours) - the exposure window measured from the evidence



Exposure window: Thu 21:15 → Tue 10:46 = 4 days 13 h 31 min (first failed update → last workstation updated)

Impact and priority after diagnosis

Confidentiality
none observed

Integrity
potential: a new threat would not have been recognized for 4.5 days

Availability
none observed

Triage (lesson 5.2)
2 × 3 = 6 → P3 (priority 3)
this week



After diagnosis
2 × 5 = 10 → P2 (priority 2)
today

*Confidence rises to 5: four independent groups prove the failure. The hand rule of lesson 5.2 (a manual rule applied after the score: a monitoring-health alert is never below **P2** (priority 2)) would already have placed A-09 in **P2** (priority 2) at triage; the score alone (6) put it in **P3** (priority 3).*

Adversary behaviour and confidence

- Assign a technique only when evidence shows the behaviour; also write the techniques tested and refuted.
- **ATT&CK** (Adversarial Tactics, Techniques, and Common Knowledge) version 19 (April 28, 2026): tactic TA0005 is named Stealth; new tactic TA0112 Defense Impairment; technique T1685 Disable or Modify Tools includes blocking updates.
- A-09: no technique; T1685 tested and refuted (change confirmed out of band, approved ticket, usual account and address).

Confidence	Criteria	Wording
High	3 or more independent groups agree, no contradiction	"The evidence shows..."
Medium	2 groups agree, or one gap remains	"The evidence indicates..."
Low	One source, or sources disagree	"One record suggests..."

Official sources: **ATT&CK** (Adversarial Tactics, Techniques, and Common Knowledge) T1685 · **ATT&CK** (Adversarial Tactics, Techniques, and Common Knowledge) TA0112

Documenting: the diagnosis record

Figure 5.4-4 Summary of the diagnosis record of CASE-2026-016 (written by New-DiagnosisRecord.ps1)

Eleven sections; every statement points to evidence (E-01 to E-11). Label: TLP:AMBER+STRICT, need-to-know.

1 What happened

Antivirus of 3 rendering workstations could not update; not an attack.

2 Category

Monitoring failure: Question 1 no, Question 2 yes.

3 Root cause

Change process without verification step or calendar entry; step 1 never done.

4 Scope and exposure

3 workstations, no account, no data; 4 days 13 h 31 min.

5 Impact and priority

C none, I potential, A none; P3 to P2 (2 × 5 = 10).

6 Adversary behaviour

None assigned; tested T1685 Disable or Modify Tools: refuted.

7 Confidence

High: 4 independent groups, no contradiction.

8 Key timeline

13 key rows with file and line; full timeline in a09_timeline.csv.

9 Actions taken

10 actions, written at the time (08:55 to 13:00).

10 Evidence register

11 files, SHA-256; 11 of 11 verified.

11 Open questions, lessons

4 lessons for the review of Friday, October 16.

Rules of the record

- Facts and interpretations apart
- Every fact: identifier, file, line
- Actions written at the time
- Uncertainty stated (confidence)

Left bar of a card: decision about the case (category, priority) · what was exposed · what makes the record trustworthy

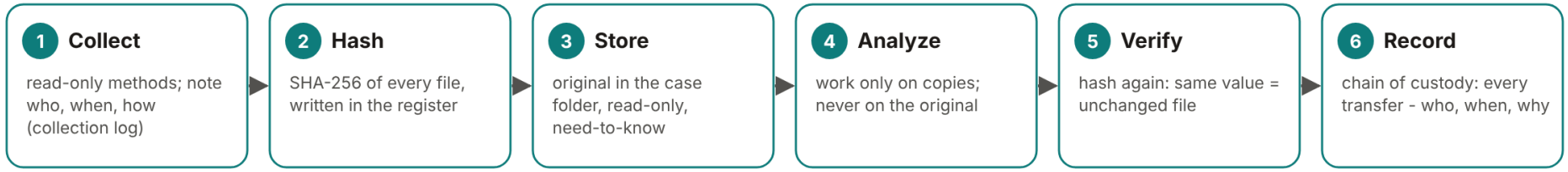
Source: outputs/A09_diagnosis_record.md and a09_diagnosis.json, written from the evidence pack and the findings of Example 5.3.

Facts apart from interpretations; every fact with identifier, file and line; actions written at the time; uncertainty stated.

Evidence integrity and chain of custody

- **SHA-256** (Secure Hash Algorithm, 256-bit): 64 hexadecimal characters computed from the bytes; one changed byte changes almost all of them.
- Register at collection, verify later, work on copies; chain of custody: every transfer, who, when, why.

Figure 5.4-3 Evidence integrity: hash at collection, work on copies, verify, record every transfer



Why a hash proves integrity: change ONE character of E-08 (on a copy) and the 64-character value changes almost completely

Original E-08 maintenance_calendar.csv: "...,Nightly backup window (backup-svc)"

`d06169e58337d1d605ac10ad504e0772d3007291c8a9e583858e612823f9deef`

Copy with one character changed: "...,Mightly backup window (backup-svc)"

`60da5e1030b61c95f721340842523f278834eb9756e9af7c5f75cd83e0d5ade2`

60 of the 64 characters differ (red). A matching hash at verification time shows the file is byte-for-byte the one collected.

Official sources: **NIST** (National Institute of Standards and Technology) **FIPS** (Federal Information Processing Standard) 180-4 · **NIST** (National Institute of Standards and Technology) **SP** (Special Publication) 800-86

Videos for lesson 5.4



Digital Forensics - CompTIA Security+ SY0-701 - 4.8

Professor Messer · 9:54 · YouTube

Chain of custody with hashes, acquisition, preservation, and what an investigation report must contain.

Watch for: Note the sentence about hashes: they prove that the data is unchanged since it was collected. That is what New-DiagnosisRecord.ps1 checks.

Watch on YouTube · **Video page and notes**
https://www.youtube.com/watch?v=UtDWApdO8Zk



Incident Planning - CompTIA Security+ SY0-701 - 4.8

Professor Messer · 6:50 · YouTube

Root cause analysis: reconstructing how a problem happened from logs and artifacts; several contributing causes, including human mistakes.

Watch for: Listen to the root cause analysis and threat hunting parts (second half of the video).

Watch on YouTube · **Video page and notes**
https://www.youtube.com/watch?v=CYFe16lCRMk

Checked October 12, 2026: confirmed by YouTube oEmbed; lengths from the official professormesser.com course index.

Example 5.4: the evidence register and the diagnosis record

TASK

Hash the 11 evidence files, verify them, decide the category, measure scope and exposure, compute the priority, write A09_diagnosis_record.md and a09_diagnosis.json.

RELATION TO THE LECTURE

Part A register, B integrity, C category, D scope, E priority, F record: the elements of lesson 5.4.

FUTURE LAB

Lab 3, Part C: the diagnosis of each **P1** (priority 1) item follows the same structure (C_diagnosis_template.md).

```
$ powershell -ExecutionPolicy Bypass -File .\scripts\New-DiagnosisRecord.ps1
outputs: evidence_register.csv · integrity_check.txt · A09_diagnosis_record.md · a09_diagnosis.json
Fictional data only; never on a real system (Legal Notice, section 6.1).
```

Example 5.4: what the script records

```
$ powershell -ExecutionPolicy Bypass -File .\scripts\New-DiagnosisRecord.ps1

A - REGISTER the evidence: SHA-256 hash, size, source, collector, time, method
  E-01  955bb8f956057d0e...     295 bytes  a09_alert.csv
  E-02  c86e083350b73925...    1649 bytes  av-console_device-status_2026-10-13.…
  E-03  98b15d43bafb2790...    1847 bytes  av-console_update-history_2026-10-08…
  ... 8 more files, 11 in total
B - VERIFY integrity: hash again and compare with the register
  11 of 11 files match their registered hash
  demo on a copy of E-08: original d06169e58337d1d605ac10ad504e0772d3007291c8a9…
C - DECIDE the category with the decision questions
  Q1 unauthorized actor or policy violation? NO - change made by contractor-it …
  Q2 monitoring or protection tool failing? YES - definitions not updated on th…
  -> category: Monitoring failure
D - MEASURE the scope and the exposure window
  exposure: Thu 2026-10-08 21:15 -> Tue 2026-10-13 10:46  (4 days 13 h 31 min)
  verified: definitions 1.441.702.0 on the three workstations; full scans: 0 th…
E - RATE the impact (CIA) and compute the priority (same scale as lesson 5.2)
  priority: impact 2 x confidence 5 = 10 -> P2 (triage had P3)
```

11 / 11

evidence files match their **SHA-256** (Secure Hash Algorithm, 256-bit) in the register

Monitoring failure

Question 1 no (confirmed by phone), Question 2 yes

4 d 13 h 31 min

exposure window, Thursday 21:15 to Tuesday 10:46

P3 → P2

impact 2 × confidence 5 = 10

Check-in: lesson 5.4

Question 1 · Multiple choice (one answer)

An intruder stops the antivirus service of a server, and the console shows "protection off". Which category applies?

a) Benign, because the console detected the change.

b) Security incident, because someone acted without authority; Question 1 is asked first and the first "yes" decides.

c) No category, because two categories apply.

d) Monitoring failure, because a protection tool is failing.

Question 2 · Multiple select (select 3)

Which practices protect the integrity of the evidence?

a) Work only on copies and keep the originals read-only.

b) Send the original files by e-mail to every stakeholder so that everyone has a copy.

c) Keep only the hash values and delete the files to save space.

d) Record every transfer of the evidence: who received it, when and why.

e) Compute the **SHA-256** (Secure Hash Algorithm, 256-bit) hash of each file at collection and write it in the register.

f) Open the original **CSV** (comma-separated values) file in a spreadsheet program and save it with formatting.

Answers and explanations: in the module (Show the answer) and in the notes of this slide.

5.5

Communicating results to the people concerned

Who must know, and who must not?

When, through which channel, under which label?

What does the law require?

Key terms of communication

Stakeholder

Affected by the problem, must act on it, or must be informed by law

Need-to-know

Information only to those who need it to do their part

Out of band

A channel separate from the systems under investigation

Communication record

Who was told what, when, how, under which label, and who was not, with the reason

Plain language

Writing the intended reader understands the first time

TLP (Traffic Light Protocol) label

Tells the recipient how far the information may be shared

Official sources: **NIST** (National Institute of Standards and Technology) **CSF** (Cybersecurity Framework) 2.0, **RS.CO** (Respond function, Incident Response Reporting and Communication category)

Who needs to know

Figure 5.5-1 Need-to-know: who receives what, through which channel, when, under which TLP label (A-09)

Person or organization	Message?	What they receive (or why not)	Channel	TLP label
Owner of Atelier Nordik	yes	What happened, what it could cost, what was done, the decisions she must take	Phone first, then the owner note by e-mail	**TLP:AMBER+STRICT**
IT contractor	yes	Timeline, evidence references, actions in priority order, lessons learned	Phone (number in the contract), then the technical annex	**TLP:AMBER**
Users of the three rendering workstations	yes	What happened, that no action is needed, whom to call	Short message (e-mail or Teams)	**TLP:GREEN**
All other staff	no	Nothing: no action needed, no data involved	-	-
Clients of Atelier Nordik	no	Nothing: no client data accessed, used, sent or lost	-	-
Commission d'accès à l'information (CAI)	no	Not a confidentiality incident: no personal information accessed, used, communicated or lost	-	-
Office of the Privacy Commissioner of Canada (OPC)	no	No breach of security safeguards involving personal information	-	-
Canadian Centre for Cyber Security (CCCS)	no	No attack: nothing to report	-	-
Police	no	No crime	-	-

A "no" is a decision too: the reason is recorded in the communication record (CAI, OPC, Cyber Centre, police: no personal information, no attack, no crime).

A "no" is a decision too: the reason is written in the communication record.

Labels: the Traffic Light Protocol 2.0

Label	Who may receive the information	Use in case A-09
TLP:RED (Traffic Light Protocol)	Only the individual recipients; no further disclosure	Not used
TLP:AMBER+STRICT (Traffic Light Protocol)	Only members of the recipient's own organization	Owner note and diagnosis record (Atelier Nordik only)
TLP:AMBER (Traffic Light Protocol)	The recipient's organization and its clients, on a need-to-know basis	Technical annex sent to the **IT** (information technology) contractor
TLP:GREEN (Traffic Light Protocol)	The community (peers and partners), not public channels	Message to the users of the rendering computers
TLP:CLEAR (Traffic Light Protocol)	Anyone; no limit except copyright	Not used: nothing of this case is public

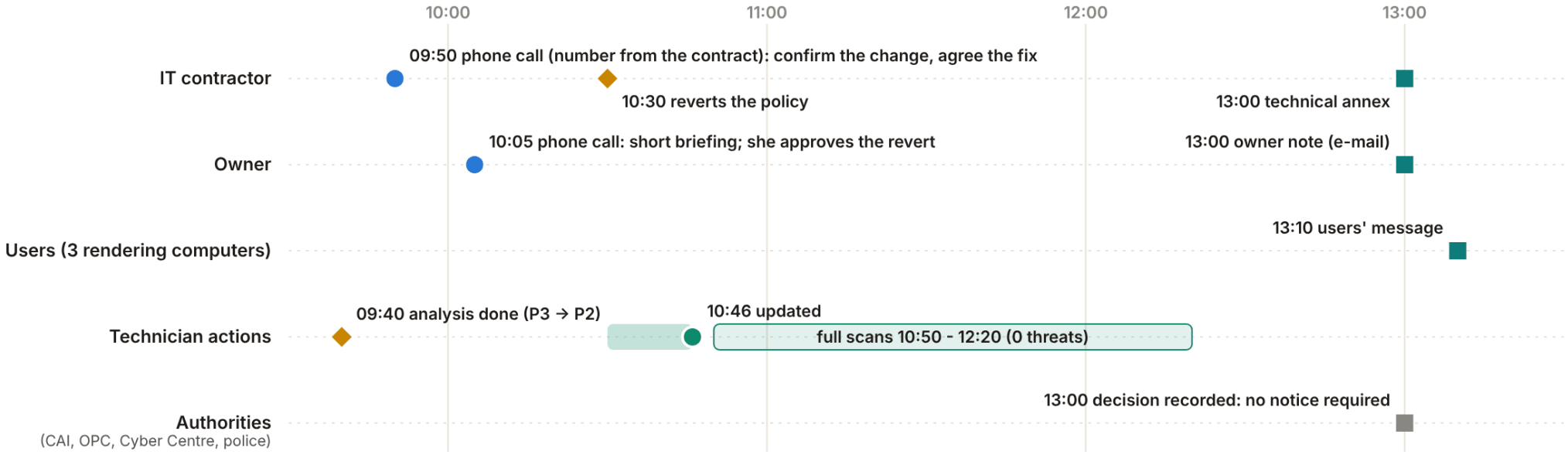
Documents: label in the header and footer of every page. E-mail: in the subject line and just before the information.

Official sources: Traffic Light Protocol 2.0

When and how: speak before you act, write after you verify

- Timing follows priority: **P1** (priority 1) now, **P2** (priority 2) today, **P3** (priority 3) this week.
- Decisions that change a system: by phone, with the owner and the contractor. Written messages after the fix is verified.
- Out of band: the number written in the contract, never one from an e-mail or the console.

Figure 5.5-2 Tuesday, October 13: speak before you act, write after you verify (EDT)



Circle = conversation · diamond = action · square = written message

Next: lessons-learned review with the contractor on Friday, October 16 (Topic 6).

One set of facts, four audiences

Audience	What they need	Language	Channel	A-09 example
Owner (decision maker)	What happened, what it could cost, what was done, what she must decide, what happens next	Plain language: no abbreviation, no host name, no code; short sentences	Phone first, then the written note	"The three rendering computers did not get antivirus updates."
IT (information technology) contractor (technical)	Timeline, evidence references (file, line, hash), actions in priority order	Technical: identifiers, codes, versions	Phone at the contract number, then the annex	"Event 2001, File share \\SRV-AD01\AVDefs, error 0x80070035."
Users affected	What happened, that no action is needed, what not to do, whom to call	Plain and short	Short message	"You do not need to do anything."
Authorities (when required)	The content that the law requires, nothing more	Precise and factual	The regulator's form or portal	Not required for A-09 (no personal information accessed, used, communicated or lost)

Same facts for everyone; only the words, the level of detail and the channel change.

The note for the owner: plain language

Five parts

1. What happened
2. What it could have cost
3. What was done
4. What we need from you (decision, date)
5. What happens next

Rules

- Canada.ca guide: sentences under 15 to 20 words, one idea each
- Canada.ca guide: active voice (who did what), everyday words
- Our rules: no abbreviations, host names, ticket numbers or codes
- Our rules: 25 words at most; Tuesday, October 13 at 10:46 am
- Facts without blame; uncertainty stated honestly

For the contractor

```
Policy Render-WS reverted at 10:30 (E-10);
definitions 1.441.702.0 at 10:46.
```

For the owner

On Tuesday morning, our computer support company changed the setting back.

Official sources: Canada.ca Content Style Guide

The same facts for two readers

Figure 5.5-3 One source of facts, two audiences (build_report.py checks the right column: 0 abbreviations)

Technical annex - IT contractor (TLP:AMBER)	Owner note - plain language (TLP:AMBER+STRICT)
WS-10-22, WS-10-37 and WS-10-51: event 2001, source File share \\SRV-AD01\AVDefs, error 0x80070035, 28 failures per workstation from Thu 21:15 to Tue 09:18 EDT.	**From Thursday, October 8 at 9:15 pm to Tuesday, October 13 at 10:46 am, the three rendering computers did not get antivirus updates.**
Root cause: CH-2026-090 step 2 applied (policy Render-WS, no fallback) without step 1 (create the share); no verification; not in the maintenance calendar.	**A setting changed on Thursday told these computers to get their updates from a shared folder on our main server. That folder was never created.**
Recovery: policy reverted 10:30 (E-10); definitions 1.441.702.0 at 10:46 (E-09); full scans 0 threats (E-11). T1685 tested, refuted.	**On Tuesday morning, our computer support company changed the setting back. A complete antivirus check of each computer then found nothing.**

Left: identifiers, codes, evidence references - for the person who makes the fix. Right: what happened, what it could cost, what was done, what she must decide.

*Technical annex for the **IT** (information technology) contractor (left); owner note in plain language (right).*

The technical annex, in the order of the Cyber Centre guide

Detection and analysis	Containment	Eradication	Recovery	Lessons learned
Timeline with file, line, **SHA-256** (Secure Hash Algorithm, 256-bit); category; root cause	Not required: no attacker; protection on	Policy reverted at 10:30 (E-10)	Definitions 1.441.702.0 at 10:44 to 10:46; full scans, 0 threats	Verification step; calendar entry; fallback source; alert after 2 failures

*Written for the person who makes the fix: identifiers, codes, versions, and evidence references (file, line, **SHA-256** (Secure Hash Algorithm, 256-bit)). Preparation happens before the incident, so the annex starts with detection and analysis.*

Official sources: Canadian Centre for Cyber Security, **ITSAP.40.003** (publication 40.003 of the Information Technology Security Awareness series of the Cyber Centre)

Québec: Law 25 and confidentiality incidents

3.1 The person with the highest authority is the person in charge of the protection of personal information (unless delegated in writing).

3.6 Confidentiality incident: unauthorized access, use or communication of personal information, its loss, or any breach of its protection.

3.5 Risk of serious injury: promptly notify the Commission d'accès à l'information and the persons concerned.

3.7 Risk assessed from sensitivity, consequences and likelihood of injurious use.

3.8 Register of every confidentiality incident, kept at least 5 years, with the reasoning on the risk.

A-09: no personal information accessed, used, communicated or lost: not a confidentiality incident; no notice, no register entry; reasoning kept in the case file.

Official sources: Act respecting the protection of personal information in the private sector (P-39.1) · Regulation respecting confidentiality incidents · Commission d'accès à l'information

Federal privacy law, Cyber Centre, police: the other checks

Rule	Trigger	Who is notified	A-09
Québec private-sector Act (as amended by Law 25)	Confidentiality incident with risk of serious injury	**CAI** (Commission d'accès à l'information du Québec) and persons concerned, promptly; register 5 years	**No: none accessed, used, sent or lost**
PIPEDA (Personal Information Protection and Electronic Documents Act) (federal)	Breach of safeguards with real risk of significant harm	**OPC** (Office of the Privacy Commissioner of Canada), individuals, organizations that can reduce harm; record 24 months	**No: none accessed, used, sent or lost**
Canadian Centre for Cyber Security	A cyber incident (voluntary for a business)	Online reporting page	**No: no attack**
Police	A suspected crime (Criminal Code, section 342.1)	Local police; emergency 911	**No: no crime**

General information, not legal advice. Each "no" is recorded with its reason (A09_notification_decision.md).

Official sources: **OPC** (Office of the Privacy Commissioner of Canada): mandatory breach reporting · Cyber Centre: report a cyber incident · Criminal Code, section 342.1

Videos for lesson 5.5

Incident Response - CompTIA Security+ SY0-701 - 4.8

Professor Messer · 9:14 · YouTube

The contact list of everyone who must be notified, documented procedures, and the post-incident meeting.

Watch for: The detection examples include "antivirus reports" and "unexpected security configuration changes": both appear in A-09.

Watch on YouTube · **Video page and notes**
https://www.youtube.com/watch?v=X2UiMLxRdhE

Compliance - CompTIA Security+ SY0-701 - 5.4

Professor Messer · 8:06 · YouTube

Compliance reporting and the cost of hiding a breach; the same reasoning applies to Law 25 and to the federal privacy law.

Watch for: Focus on the example of a breach that was hidden for about a year and on what it cost.

Watch on YouTube · **Video page and notes**
https://www.youtube.com/watch?v=IjJf4jLtONQ

Checked October 12, 2026: confirmed by YouTube oEmbed; lengths from the official professormesser.com course index.

Example 5.5: write the messages from one set of facts

TASK

From a09_diagnosis.json: decide the legal notices, choose audiences, channel, time and label, write and check the owner note, write the annex, save the communication record.

RELATION TO THE LECTURE

Step 2 law (5.5.8), step 3 who and how (5.5.2 to 5.5.4), step 4 plain language (5.5.6), step 5 annex (5.5.7), step 6 records.

FUTURE LAB

Lab 3, Part D: one page for the owner and a technical annex for the contractor (D_report_template.md).

```
$ python3 scripts/build_report.py
outputs: A09_owner_note.md · A09_technical_annex.md · A09_staff_message.md · A09_notification_decision.md · A09_communication_plan.csv
Fictional data only; never on a real system (Legal Notice, section 6.1).
```

Example 5.5: the owner note, checked

Figure 5.5-4 Structure of the owner note (the text written by build_report.py, unchanged)

Five parts, plain language, one decision with a date. Model for the owner page of Lab 3, Part D.

TLP:AMBER+STRICT - internal to Atelier Nordik, do not forward.

Antivirus updates on the three rendering computers

To: the owner of Atelier Nordik. From: the monitoring technician. Tuesday, October 13, 1:00 pm.

What happened

From Thursday, October 8 at 9:15 pm to Tuesday, October 13 at 10:46 am, the three rendering computers did not get antivirus updates. These updates bring the list of known threats. A setting changed on Thursday told these computers to get that list from a shared folder on our main server. That folder was never created. This was a mistake in a planned change. It was not an attack.

What it could have cost

For four and a half days, a new threat could have reached these computers without being recognized. Nobody saw, changed or lost our files or our clients' information.

- Who can see our information: not affected.
- Whether our files are correct: not affected, but at risk during these four and a half days.
- Whether we can use our computers and files: not affected.

What was done

On Tuesday morning, our computer support company changed the setting back. A complete antivirus check of each computer then found nothing. Everything we found is kept in the case file.

What we need from you

Please approve two rules before Friday, October 16. First, every planned change must say how we will check that it worked. Second, every planned change goes into our maintenance calendar.

What happens next

No personal information was seen, used, sent or lost. Québec law therefore does not require us to notify the Commission d'accès à l'information or anyone else. We will review this change with our computer support company on Friday, October 16. Questions: call me.

TLP:AMBER+STRICT - internal to Atelier Nordik, do not forward.

What happened
Facts only, in order; dates and times written in full; "It was not an attack" stated once.

What it could have cost
The three properties in everyday words: who can see the information, is it correct, can we use it. Possible versus observed.

What was done
Active voice: who did what. Verified result. Evidence kept.

What we need from you
One decision, with a date (Friday, October 16): two rules for planned changes.

What happens next
Legal decision and its reason (no personal information, no notice). Next meeting. Whom to call.

Automatic check (build_report.py, step 4)

- ✓ 0 abbreviations, identifiers, codes or paths in the text
- ✓ 10 technical terms replaced by plain words
- ✓ Longest sentence: 23 words (limit 25)
- ✓ Label TLP:AMBER+STRICT at the top and the bottom

5 parts

what happened, cost, done, decision, next

0

abbreviations, identifiers, codes or paths

23 words

longest sentence (limit 25)

1 decision

with a date: Friday, October 16

Check-in: lesson 5.5

Question 1 · Multiple choice (one answer)

During the analysis, the technician wants to confirm that the contractor really made the change of Thursday 17:42. Which channel is correct?

a) Send a message through the antivirus console.

b) Reply to the latest e-mail received from the contractor.

c) Call the phone number written in the service contract.

d) Call the number shown in the signature of an e-mail received on Thursday.

Question 2 · Multiple select (select 3)

For A-09, who receives a message?

a) The owner of Atelier Nordik.

b) All the clients of Atelier Nordik.

c) The **IT** (information technology) contractor.

d) The users of the three rendering workstations.

e) The Canadian Centre for Cyber Security.

f) The Commission d'accès à l'information.

Answers and explanations: in the module (Show the answer) and in the notes of this slide.

Quiz 3 (5%): Topics 3 and 4

Coverage

- 3.1 Categories of monitoring tools
- 3.2 Selecting the right tool for a given need
- 3.3 Installing monitoring tools and applying updates
- 3.4 Creating the reference database (baseline)
- 3.5 Configuring alerts for suspicious behaviours
- 4.1 Event logs: Windows and Linux
- 4.2 Network traffic capture: the basics

Topic 5 (lessons 5.1 to 5.5) is not in Quiz 3.

How to prepare

- Key terms and tables of Classes 8, 11, 12, 13, 14
- Self-check questions and practice tests of those classes
- One example per lesson, in your own words
- Multiple select: the number of answers is given
- Individual work; questions confidential (section 17.2)

Official sources: Dawson College **ISEP** (Institutional Student Evaluation Policy) · Legal Notice, section 17

Lab 3: what today gives you

Part	Points	What you write	What today gives you
C Diagnose	30	C_diagnosis.md: two **P1** (priority 1) items, five steps	Lessons 5.3, 5.4; two scripts; two templates
D Report	15	D_report.md: owner page and technical annex	Lesson 5.5; build_report.py; template; checker
E Optimize	10	E_optimisation.md	Topic 6 tomorrow; the four A-09 lessons
A, B, Form	20, 20, 5	Detect, sort, form	Classes 14 and 15; **ISEP** (Institutional Student Evaluation Policy); section 18.2

Due Monday, October 19, 2026, 23:59 EDT (Eastern Daylight Time): one ZIP in Omnivox, Léa, Lab 03. Minus 10% per day; nothing after 7 days.

Official links (1/2): standards and methods

NIST (National Institute of Standards and Technology) SP (Special Publication) 800-61 Revision 3
Current incident response guide (April 2025)

NIST (National Institute of Standards and Technology) Cybersecurity Framework 2.0
Respond: Incident Analysis; Reporting and Communication

IETF (Internet Engineering Task Force) RFC (Request for Comments) 3227
Evidence collection and archiving; order of volatility

NIST (National Institute of Standards and Technology) FIPS (Federal Information Processing Standard) 180-4
Secure Hash Standard: defines **SHA-256** (Secure Hash Algorithm, 256-bit)

NIST (National Institute of Standards and Technology) SP (Special Publication) 800-86
Forensic techniques in incident response

Cyber Centre: Developing your incident response plan
Phase order of the technical annex

Traffic Light Protocol 2.0
Forum of Incident Response and Security Teams: the five labels

Canada.ca Content Style Guide
Plain-language rules for the owner note

MITRE ATT&CK (Adversarial Tactics, Techniques, and Common Knowledge)
Adversary tactics and techniques; version 19 since April 28, 2026

ATT&CK (Adversarial Tactics, Techniques, and Common Knowledge) technique T1685
Disable or Modify Tools: tested and refuted for A-09

Checked October 12, 2026. Before opening a link, check it (VirusTotal, Google Safe Browsing): Legal Notice, Annex C. The full list is in the module.

Official links (2/2): law, vendors, safety

Québec private-sector privacy Act (chapter P-39.1)
Sections 3.1 and 3.5 to 3.8: confidentiality incidents

Criminal Code of Canada, section 342.1
Unauthorized use of a computer

Regulation respecting confidentiality incidents
Content of the register; kept at least 5 years

Microsoft Defender Antivirus event reference
Events 1000, 1001, 2000 and 2001

Commission d'accès à l'information du Québec
Receives notices of confidentiality incidents

Microsoft Defender update sources
File shares and the fallback order

Privacy Commissioner of Canada: breach reporting
Real risk of significant harm; record kept 24 months

VirusTotal URL (Uniform Resource Locator) scanner
Check a link before you open it

Cyber Centre: report a cyber incident
Voluntary online reporting for businesses

Cyber.SoHo Legal Notice, v2.0
Terms of use, acceptable use, monitoring data, evidence

Checked October 12, 2026. Before opening a link, check it (VirusTotal, Google Safe Browsing): Legal Notice, Annex C. The full list is in the module.

Next class and thank you

Next
Class 17, Friday, October 16 (online): Topic 6, Optimizing the Monitoring Setup: 6.1 reference databases, 6.2 impact on the network, 6.3 coverage, 6.4 fewer false alarms, 6.5 recommending tools.

Before Class 17
- ✓ Watch the six videos (56 minutes)
- ✓ Run the three scripts in order
- ✓ Start Lab 3, Part C

Thank you. Quiz 3 starts after the break.

Use of this material is governed by the Cyber.SoHo Legal Notice, Terms of Use and Acceptable Use Policy (v2.0): link on slides 2 and 54.
All data are fictional. Quizzes, datasets and solutions are confidential.

Educational Hub © 2026 | From the Industry to the Classroom — Building the IT's Future, Today and Together ! ALL Rights Reserverd